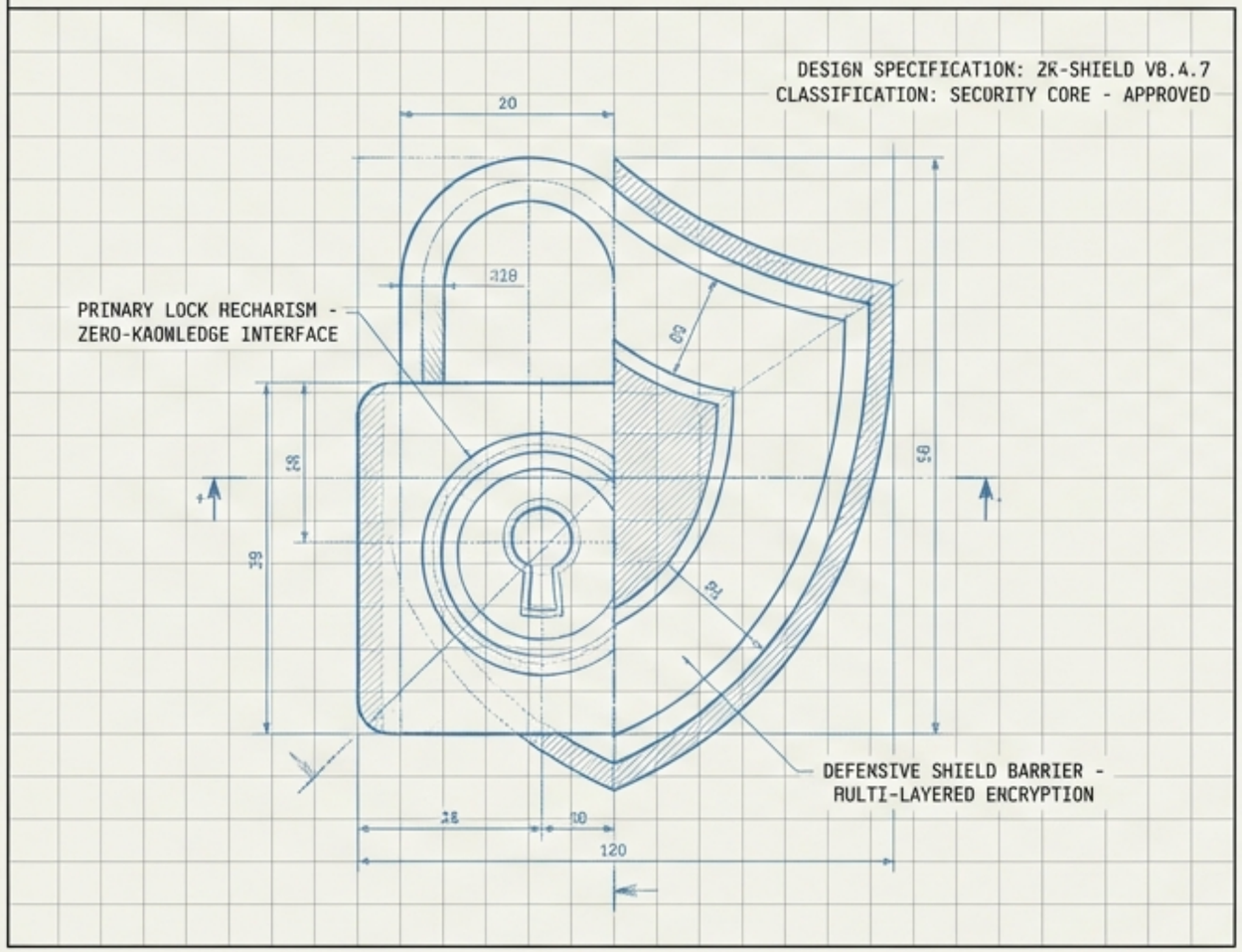
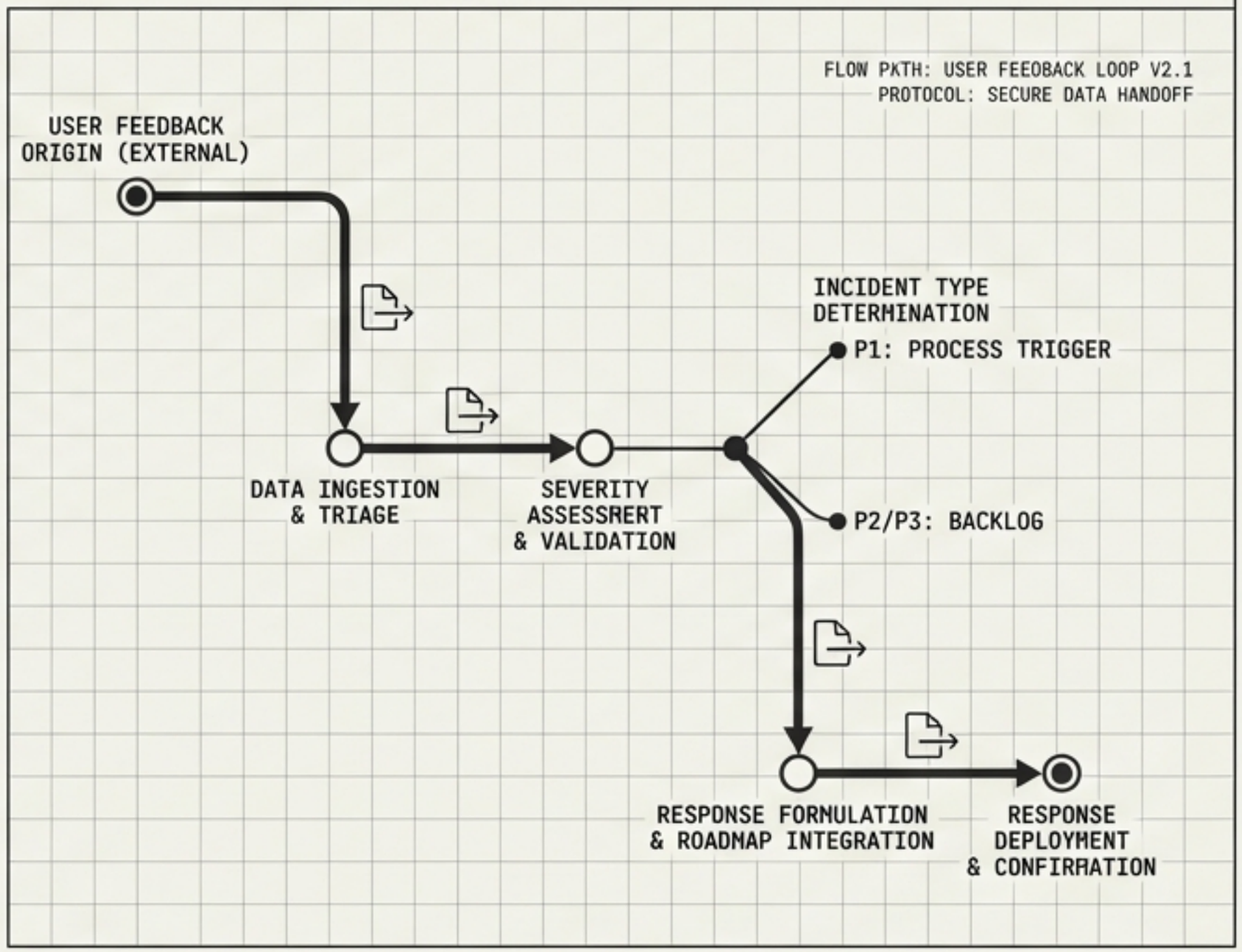
Security Review & User Feedback: Incident Report & Response

Validation of Zero-Knowledge Model, Severity Reclassification, and Roadmap Alignment





DATE: 17 FEB 2026	STATUS: P1 INCIDENT (PROCESS TRIGGER)	PRODUCT: V0.4.7	SOURCE: EXTERNAL SECURITY REVIEW & BETA

The Shield Held: Zero-Knowledge Confirmed, Process Tested

THE VALIDATION

Source: 2 Beta Users (User A & User B)

Scope: Full-Stack Review (Crypto, Backend, Admin, CI/CD)

Verdict: AES-256-GCM **correct** via Web Crypto API. **Server never sees plaintext or keys.**

THE INCIDENT

29
Total Findings

0
Critical Crisis / P0

0
Customer Data at Risk

3
Must-Fix Before Prod / P3

THE FUTURE

Roadmap Alignment: 12 of 13 feature requests were already planned.

Next Steps: Fix **P3s** immediately; formalize vulnerability disclosure process.

“I can’t tell you how many times I’ve needed something like this. I mean if you use Signal, Proton, or whatever else, the other party needs the s[redacted]ame tech, which is not always the case, right?”

— User A

THE KILLER FEATURE

Validated: Recipient only needs a browser + key.
No account. No app. No sign-up.

[x] Crypto Sound
[x] Zero-Knowledge Holds
[x] No Data Compromised

Why P1? Setting the Standard for Disclosure

We triggered a P1 Incident to test our response protocol, not because of a crisis.

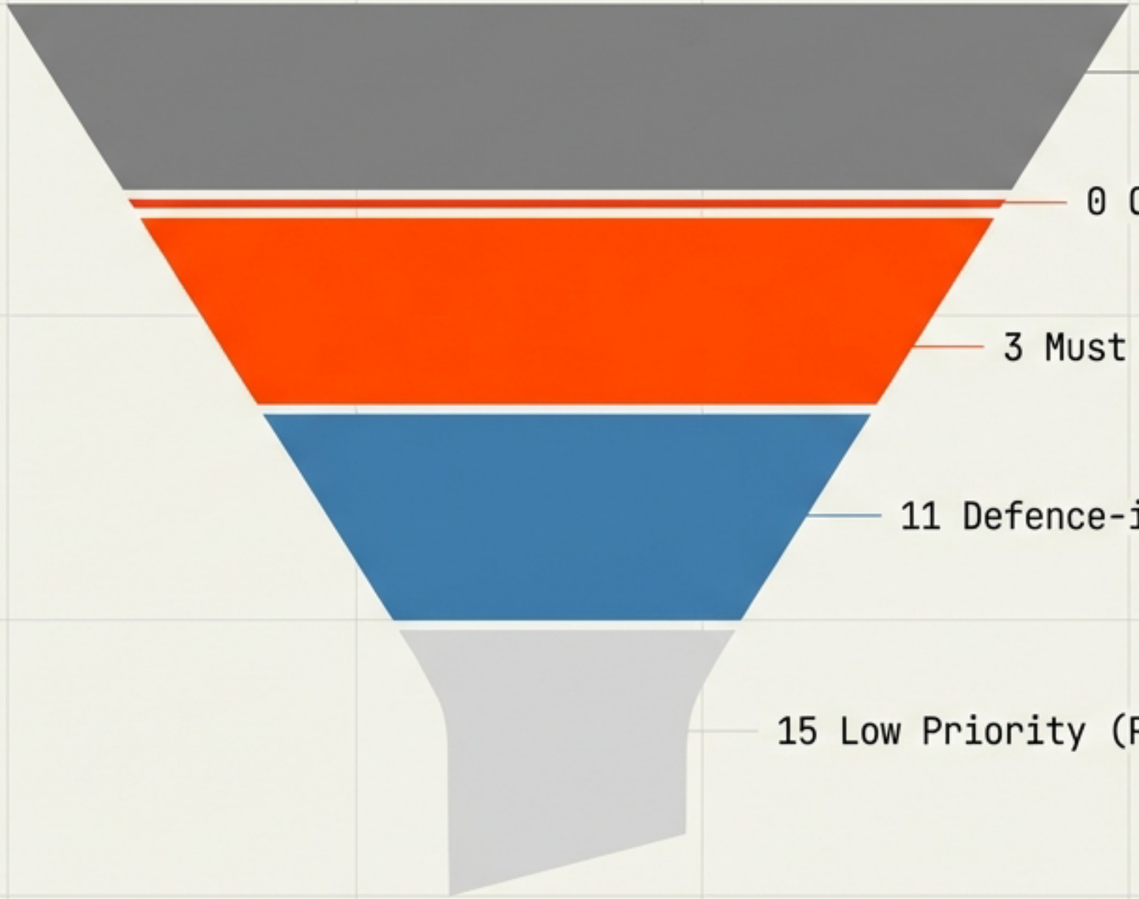
- **First External Disclosure:** Setting the precedent.
- **Comprehensive Report:** 29 findings required structured analysis.
- **Stakeholder Relationship:** The reporter is a key partner.

Severity Translation Table

Reviewer Scale		Business Impact Scale
High	→	**P3** (Must fix before production)
Critical	→	**P0** (Crisis - None Found)

Reviewer's findings mapped here. No real customer data currently at risk.

Findings by Business Impact



29 Total Findings

0 Crisis Level (P0/P1/P2) No immediate shutdown required.

3 Must Fix Before Prod (P3) Critical work for Explorer Team.

11 Defence-in-Depth (P4/P5) Supply chain, rate limiting.

15 Low Priority (P6-P8) Minor improvements.

Priority Actions: The 3 Critical Fixes (P3)

AUTH FAILS OPEN

DATA | ZS00-09/-3

Risk: If config is missing, auth silently skips. Dangerous pattern.

```
</> Admin__Service__Client__Setup.py
...
  ...
...
```

Fix: Fail closed at startup. Raise exception.

PLAINTEXT IN LOCALSTORAGE

DATA | ZS00-07/-3

Risk: XSS could exfiltrate decryption history. Undermines Zero-Knowledge.

```
</> send-download.js
...
  ...
...
```

Fix: SessionStorage + Encryption. Make history opt-in.

TOKEN RACE CONDITION

DATA | ZS08-07/-3

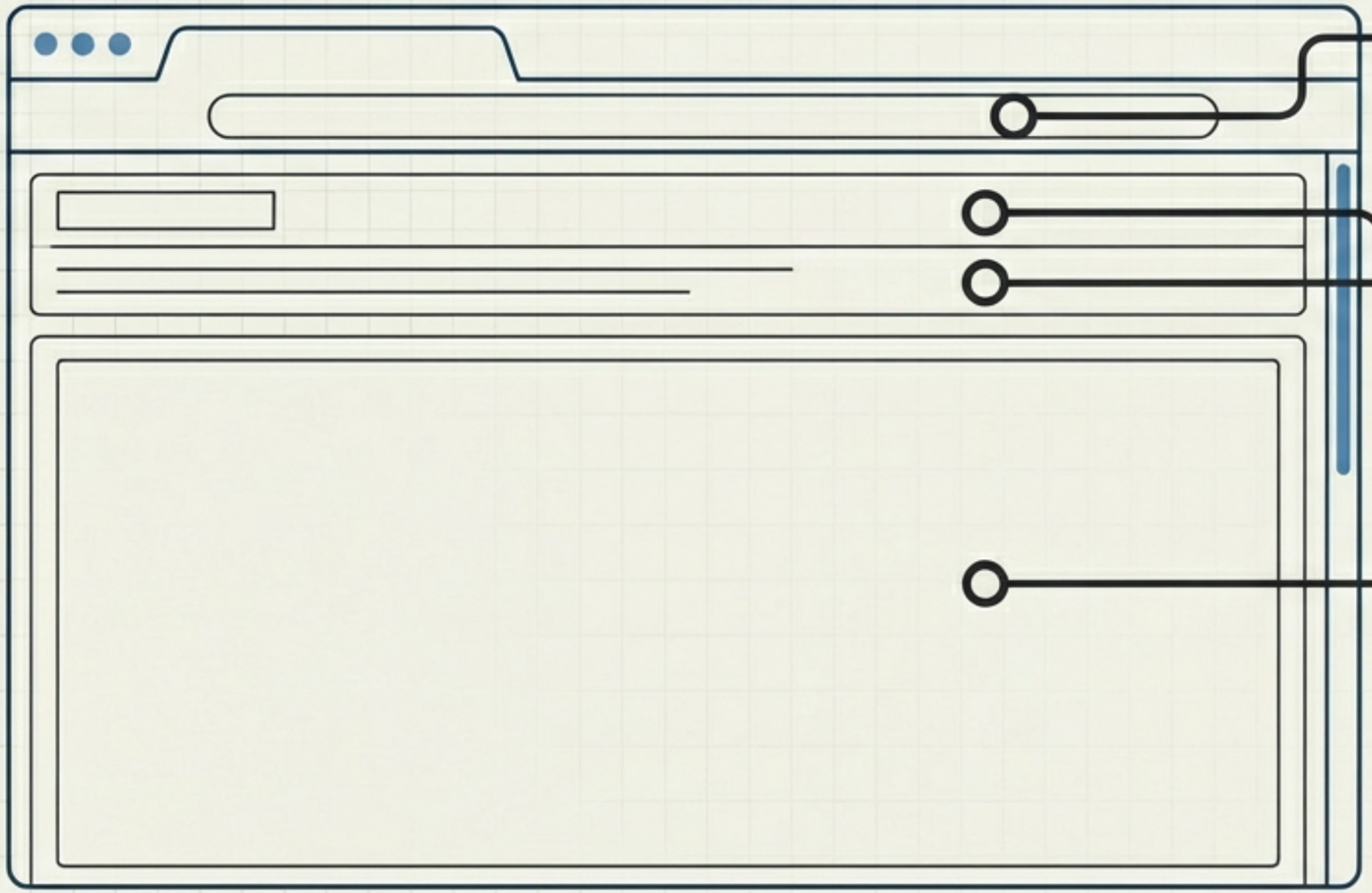
Risk: Concurrent requests bypass limits via non-atomic read-modify-write.

```
</> Service__Tokens.py
...
  ...
...
```

Fix: Atomic database increments (DynamoDB).

Strengthening the Browser Environment

The Zero-Knowledge model is threatened most by the client-side, not the server.



URL Hygiene

Issue: Key remains in URL hash.
Fix: Clear hash immediately after extraction.

Content Security Policy (CSP)

Issue: Missing.
Fix: Move inline JS to external files to enable nonce-based CSP.

The Markdown Win

Issue: Reports render as raw text.
Fix: Render markdown in a sandboxed iframe.

```
<sandbox="allow-same-origin">
```

Privacy by Design: The Pivot on IP Logging

THE CONFLICT

- Code contained IP hashing logic (unused).
- README claimed "SHA-256 with salt" (did not exist).
- DPO requirement: "No IP addresses stored."

THE RESOLUTION →

1. **Action:** Remove dead hashing code entirely.
2. **Documentation:** Correct README to reflect reality.
3. **New Direction:** Do not store IPs.
4. **Research:** Investigate Browser Fingerprinting for audit trails.

Listening to the Community: Roadmap Alignment

User Requests	Roadmap Items
Expiring Links (User B)	Planned: TTL / Investor Doc
User Keys (User B)	Planned: Key Mgmt
Cert-Based Encryption (User B)	Planned: PKI
Sender-side Deletion (User A)	Planned: Data Room Mgmt
Download Limits (User A)	Planned: One-time Access

12 of 13 Suggestions Already Planned.
Added: Download Notifications.

Turning Feedback into Operational Process

DISCLOSURE

Deploying `security.txt`. Establishing a formal Bug Bounty & Hall of Fame.

- Eating our own dog food: Reports submitted via SG/Send token.

RISK MANAGEMENT

GRC to classify all findings.

- Risk Acceptance: Formal sign-off required for 'No Fix' decisions.

TRANSPARENCY

Publish a Vulnerability Register on the docs site.

Strategic Research: The ‘Firefox Send’ Lesson

Context: Firefox Send was shut down due to malware abuse (unscannable encrypted files).

The Challenge & Response

Problem: How to prevent abuse while maintaining Zero-Knowledge?

Research Tasks (Ambassador + AppSec):

1. **Abuse Signaling:** Detecting volume anomalies without inspecting content.
2. **Takedown Process:** Operational workflows for reported abuse.
2. **Takedown** Facinaling.
3. **Legal:** Terms of Service and regulatory protections.

Immediate Action Plan

EXPLORER TEAM (CODE)

- Fix P3s (Auth, LocalStorage, Race Condition).
- Research Browser Security & Secrets/2FA.

VILLAGER TEAM (DEPLOY)

- Deploy fixes via production pipeline.
- Sherpa to manage User B relationship.

AMBASSADOR (MESSAGE)

- Build messaging around “No App Needed”.
- Research Firefox Send abuse patterns.

GRC (GOVERN)

- Publish Vulnerability Register.
- Correct README (IP claims).

Ready for the Next Phase

The crypto is sound. The model works. Now we prove we can respond quickly and transparently.

Next Steps

- [ ] Execute P3 Fixes (Explorer)
- [ ] Publish Security Advisory (Transparency)
- [ ] Invite More Beta Users (Growth)